

Unit 1: Ethical Hacking Overview

Part 1

By Dr. Indu Singh
CSE Dept, DTU

Dr. Indu Singh CSE DTU

Introduction to Ethical Hacking

Ethical hackers are cybersecurity professionals who are **authorized** to identify, test, and fix security weaknesses before malicious attackers can exploit them.

Skills Required by an Ethical Hacker

- Knowledge of networking and operating systems.
- Understanding of web application and database security.
- Familiarity with penetration testing tools (e.g., Nmap, Burp Suite, Metasploit).
- Programming and scripting skills (Python, Bash, PowerShell).

Introduction to Ethical Hacking

Characteristics

- Work only with the organization's permission.
- Follow legal and ethical guidelines.
- Maintain confidentiality of sensitive information.
- Use the same tools and techniques as malicious hackers, but for defensive purposes.

Benefits

- Prevents cyberattacks before they occur.
- Protects sensitive data and business operations.
- Reduces financial and reputational risks.
- Strengthens an organization's cybersecurity defenses.

Penetration Testing

- **Penetration testing (Pen Testing)** is an authorized simulated cyberattack performed to identify security vulnerabilities.
- It evaluates the security of networks, web applications, systems, and databases.
- Mimics the techniques used by real attackers to test an organization's defenses.
- Helps determine the impact and exploitability of discovered vulnerabilities.
- Conducted only with the organization's permission and within a defined scope.

Penetration Testing: Real-Life Example

A company hires security professionals to test its online banking website. The penetration testers discover an SQL Injection vulnerability that could expose customer data. The issue is fixed before any attacker can exploit it.

Roles and Responsibilities of an Ethical Hacker

- Identify vulnerabilities in networks, systems, applications, and databases.
- Simulate real-world cyberattacks in a controlled and authorized environment.
- Assess the impact and severity of discovered security flaws.
- Document findings with detailed technical reports.

Roles and Responsibilities of an Ethical Hacker

- Recommend security improvements and mitigation strategies.
- Verify that vulnerabilities are properly fixed through retesting.
- Help organizations comply with security standards and regulations (e.g., ISO 27001, PCI DSS).
- Promote security awareness and best practices within the organization.

Why Ethical Hacking is Important

- Helps organizations understand attacker techniques and identify how cybercriminals think and operate.
- Identifies security vulnerabilities before attackers exploit them, reducing the risk of successful cyberattacks.
- Strengthens network, application, and system defenses by discovering and fixing security weaknesses.
- Protects sensitive business and customer data from unauthorized access, theft, or manipulation.
- Reduces the risk of financial losses caused by cyberattacks, ransomware, and data breaches.

Why Ethical Hacking is Important

- Ensures compliance with security standards and regulations such as ISO 27001, PCI DSS, and GDPR.
- Improves incident response and security preparedness by testing an organization's ability to detect and respond to attacks.
- Enhances customer trust and organizational reputation by demonstrating a commitment to cybersecurity.
- Supports continuous security improvement through regular security assessments and penetration testing.
- Minimizes downtime and business disruption by identifying and resolving vulnerabilities before they impact operations.

Ethical Hacking Terminologies

- **Ethical Hacker:** Authorized professional who tests security to identify and fix vulnerabilities.
- **Penetration Testing:** Simulated cyberattack performed to identify exploitable security weaknesses.
- **Vulnerability Assessment:** Process of identifying, analyzing, and prioritizing security weaknesses.
- **Exploit:** Code or technique used to take advantage of a vulnerability.
- **Authorization:** Official written permission required before conducting security testing.

Ethical Hacking Terminologies

- **Scope:** Defines the systems, networks, and activities allowed during testing.
- **Threat:** Any potential event or actor capable of causing harm to a system.
- **Vulnerability:** A weakness in software, hardware, or processes that can be exploited.
- **Risk:** The likelihood and potential impact of a threat exploiting a vulnerability.
- **Attack Surface:** The total number of points where an attacker can attempt unauthorized access.

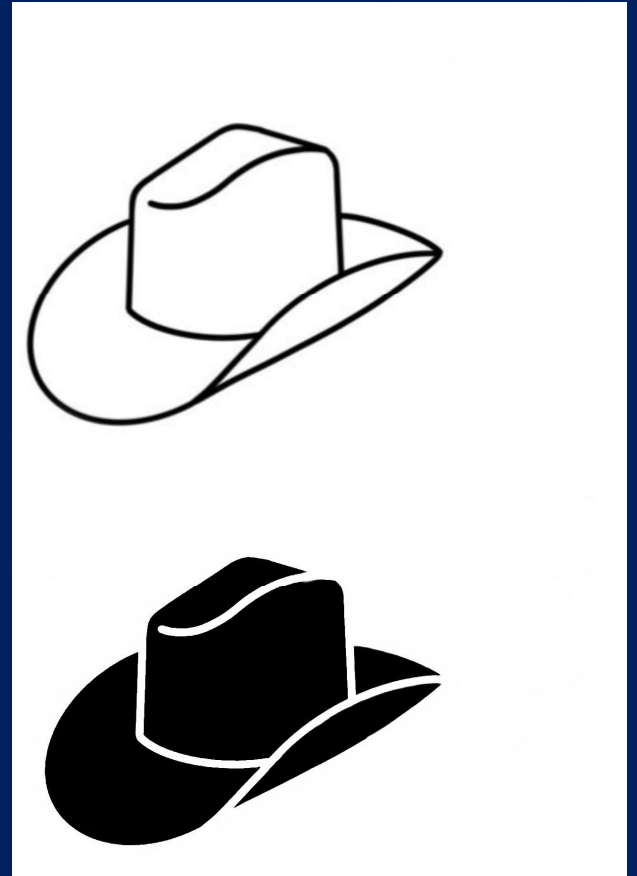
White Hat vs Black Hat

White Hat:

- Authorized
- Improves security
- Works within scope

Black Hat:

- Unauthorized
- Personal gain or malicious intent
- Exploits vulnerabilities



White Hat Hacker

A White Hat hacker is an authorized cybersecurity professional who uses ethical hacking techniques to identify and fix security weaknesses.

Key Characteristics

- Works with the permission of the organization.
- Follows legal and ethical guidelines.
- Conducts security assessments and penetration tests.
- Reports vulnerabilities responsibly.
- Helps strengthen the organization's security posture.

Example: A company hires a penetration tester to assess its website security and recommend fixes for any discovered vulnerabilities.

Black Hat Hacker

A Black Hat hacker is an unauthorized individual who exploits security vulnerabilities for personal gain, financial profit, or malicious purposes.

Key Characteristics

- Operates without permission.
- Violates laws and ethical standards.
- Steals, alters, or destroys data.
- Exploits vulnerabilities for personal benefit.
- Can cause financial loss, reputational damage, and service disruption.

Example: A hacker gains unauthorized access to a company's database and steals customer information to sell on the dark web.

Types of Hacking Technologies

- Network Hacking
- Web Application Hacking
- Wireless Network Hacking
- System/OS Hacking
- Social Engineering
- Malware-based Attacks

Network Hacking

Network hacking focuses on compromising computer networks and communication systems.

Common Activities

- Port scanning
- Packet sniffing
- Password attacks
- Network enumeration

Goal

- Gain unauthorized access to network resources.

Network Hacking

Common Activities:

Port Scanning: Identifies open ports and running services on a target system.

Packet Sniffing: Captures and analyzes network traffic to inspect transmitted data.

Password Attacks: Attempts to obtain user passwords using methods like brute force or dictionary attacks.

Network Enumeration: Collects information about network devices, users, shares, and services to identify potential targets.

Web Application Hacking

Targets websites and web applications to identify vulnerabilities.

Common Attacks

- SQL Injection
- Cross-Site Scripting (XSS)
- File Inclusion attacks

Goal

- Access databases, steal data, or compromise web servers.

Web Application Hacking

Common Attacks

- **SQL Injection (SQLi):** Injects malicious SQL commands to access or manipulate a database.
- **Cross-Site Scripting (XSS):** Injects malicious scripts into web pages that execute in users' browsers.
- **File Inclusion Attacks:** Exploit vulnerable applications to include unauthorized local or remote files, potentially leading to code execution.

Wireless Network Hacking

Targets wireless communication technologies like Wi-Fi.

Common Activities

- Cracking Wi-Fi passwords
- Rogue access points
- Packet capture

Goal

- Gain access to wireless networks.

Wireless Network Hacking

Common Activities

- **Cracking Wi-Fi Passwords:** Attempts to recover a wireless network's password to gain unauthorized access.
- **Rogue Access Points:** Sets up a fake Wi-Fi hotspot to trick users into connecting and intercept their data.
- **Packet Capture:** Records network packets to analyze traffic and identify security issues or sensitive information.

System Hacking

Focuses on compromising operating systems and computers.

Activities

- Password cracking
- Privilege escalation
- Malware installation

Goal

- Gain administrative control over systems.

System Hacking

Activities

- **Password Cracking:** Attempts to recover user passwords using techniques such as brute force or dictionary attacks.
- **Privilege Escalation:** Exploits vulnerabilities to gain higher-level access or administrative privileges.
- **Malware Installation:** Installs malicious software to steal data, disrupt systems, or maintain unauthorized access.

Social Engineering

Manipulates people into revealing sensitive information.

Examples

- Phishing emails
- Fake calls
- Impersonation

Goal

- Exploit human weaknesses instead of technical flaws.

Social Engineering

Examples

- **Phishing Emails:** Fraudulent emails designed to trick users into revealing sensitive information or clicking malicious links.
- **Fake Calls:** Phone calls where attackers pose as trusted individuals to obtain confidential information.
- **Impersonation:** Pretending to be a legitimate person or organization to deceive victims into granting access or sharing data.

Malware-Based Hacking

Uses malicious software to compromise systems.

Types of Malware

- Viruses
- Worms
- Trojans
- Ransomware

Goal

- Damage systems, steal information, or maintain unauthorized access.

Malware-Based Hacking

Types of Malware

- **Virus:** Malicious software that attaches to legitimate files and spreads when the infected file is executed.
-
- **Worm:** Self-replicating malware that spreads automatically across networks without user interaction.
- **Trojan:** Malware disguised as legitimate software to trick users into installing it.
- **Ransomware:** Malware that encrypts files or locks systems and demands payment to restore access.

Examples of Hacking Technologies

- Network: Port scanning, enumeration.
- Web: SQL Injection, web server attacks.
- Wireless: WLAN security testing.
- System: Exploiting OS vulnerabilities.
- Social Engineering: Human-focused attacks.

Phases of Ethical Hacking

The Five Phases Of Ethical Hacking



Reconnaissance/
Footprinting



Scanning



Gaining
Access



Maintaining
Access



Clearing
Tracks

Phases of Ethical Hacking

1. Reconnaissance
2. Scanning & Enumeration
3. Exploitation
4. Maintaining Access
5. Reporting / Wrap-up

Reconnaissance

Reconnaissance is the **first phase of ethical hacking** in which information about the target is collected to understand its infrastructure and identify potential attack vectors.

Information Collected

- IP addresses and network ranges
- Domain names and subdomains
- Employee names, email addresses, and contact details
- Network structure and topology
- Operating systems and technologies used

Reconnaissance

Objectives

- Identify potential entry points into the target.
- Gather intelligence for later phases such as scanning and enumeration.
- Understand the target's network architecture.
- Detect publicly exposed systems and services.
- Minimize unnecessary interaction during later testing.

Scanning

- Scanning is the phase in which the target is **actively analyzed** to identify live hosts, open ports, running services, operating systems, and potential security vulnerabilities.

Activities

- Port scanning to identify open ports.
- Service detection to determine running services and versions.
- Vulnerability scanning to detect known security weaknesses.
- User and network resource enumeration.
- Operating system fingerprinting.
- Network mapping to identify active hosts and devices.

Scanning

Objectives

- Discover active systems on the network.
- Identify open ports and exposed services.
- Detect outdated software and known vulnerabilities.
- Gather information for further penetration testing.
- Verify firewall rules and network security configurations.

Exploitation

Exploitation is the phase in which identified vulnerabilities are **safely exploited** to determine whether unauthorized access or other security impacts are possible. In ethical hacking, this is performed **only with authorization and within the defined scope**.

Techniques

- Password attacks to test authentication strength.
- Exploit execution using known vulnerabilities.
- SQL Injection to access or manipulate databases.
- Buffer overflow attacks to execute arbitrary code.
- Cross-Site Scripting (XSS) exploitation.

Exploitation

Objectives

- Verify that discovered vulnerabilities are exploitable.
- Assess the potential impact of a successful attack.
- Determine the level of access an attacker could obtain.
- Identify weaknesses in authentication and access controls.
- Demonstrate real-world security risks to the organization.

Expected Outcomes

- Unauthorized access to systems or applications.
- Access to sensitive data (within the approved scope).
- Elevated user privileges.
- Evidence of security weaknesses for remediation.

Maintaining Access

Maintaining access is the phase in which an attacker attempts to **retain persistent access** to a compromised system for future use. In ethical hacking, this phase is **simulated only when explicitly authorized** to assess the effectiveness of security controls.

Methods

- Installing backdoors for persistent remote access.
- Creating hidden or unauthorized user accounts.
- Deploying malware or remote access tools (RATs).
- Modifying startup services or scheduled tasks.
- Stealing or reusing valid credentials.

Maintaining Access

Objectives

- Evaluate whether persistent access can be established.
- Test the organization's ability to detect unauthorized access.
- Assess the effectiveness of endpoint security and monitoring.
- Identify weaknesses in access controls and system hardening.
- Demonstrate the potential impact of a successful compromise.

Potential Risks

- Long-term unauthorized access to systems.
- Theft or manipulation of sensitive data.
- Installation of additional malicious software.
- Use of the compromised system to attack other devices.

Reporting

Reporting is the final phase of ethical hacking, where all findings are **documented, analyzed, and communicated** to the organization along with recommendations for remediation.

Ethical Hacker Activities

- Prepare detailed security assessment reports.
- Document identified vulnerabilities and affected systems.
- Assign risk levels based on severity and potential impact.
- Provide proof of concept (PoC) or evidence of successful exploitation.
- Recommend remediation and mitigation strategies.

Reporting

Objectives

- Help the organization understand its security posture.
- Prioritize vulnerabilities based on business risk.
- Guide administrators in fixing security issues.
- Improve overall cybersecurity and prevent future attacks.

Reporting

Contents of a Security Report

- Executive summary
- Scope of the assessment
- Methodology and tools used
- List of vulnerabilities discovered
- Risk ratings (Critical, High, Medium, Low)
- Evidence and screenshots
- Remediation recommendations
- Conclusion and overall security assessment

Conclusion

- Ethical hacking enables organizations to proactively identify, assess, and mitigate security vulnerabilities before they can be exploited by malicious attackers.
- It follows a structured methodology, including reconnaissance, scanning, enumeration, exploitation, maintaining access (when authorized), and reporting.
- Ethical hackers use the same techniques and tools as attackers but operate legally, ethically, and with explicit authorization.
- A successful ethical hacking engagement requires defined scope, written authorization, technical expertise, and adherence to ethical guidelines.
- The findings are documented in detailed security reports, along with risk assessments and remediation recommendations.